PROJECT NEXUS CLOUD

System Structure, Sprint Development Plan and SDLC Test Strategy

Derived from the Concept Development & Technical Architecture Blueprint v1.0

PREPARED FOR
Henry Ugochukwu (owner, architect, developer, tester, PM)

VERSION
1.0 · 28 October 2026

STATUS
Approved for planning — awaiting the go-ahead for Sprint 0

CADENCE
Sprint 0 = 1 week; Sprints 1–13 = 2 weeks each (solo developer + AI agents)

Working name only. Check domain, company-name and trademark availability before public use.

Contents

1. Purpose and How to Use This Plan 4

Sprint cadence and ceremonies . . . 4

2. System Structure 5

2.1 Logical architecture . . . 5

2.2 End-to-end request flow . . . 5

2.3 Repository layout (pnpm workspaces + Turborepo) . . . 6

2.4 Module boundaries and rules . . . 6

2.5 Data model (initial migrations) . . . 7

3. Release Roadmap Overview 8

4. Sprint-by-Sprint Development Plan 9

Sprint 0 — Foundation . . . 9

Sprint 1 — Identity, App Shell and Audit . . . 9

Sprint 2 — Project Cockpit . . . 10

Sprint 3 — GitHub Integration . . . 11

Sprint 4 — Repository Workspace . . . 11

Sprint 5 — Model Gateway and Cost Control . . . 12

Sprint 6 — Agents Vertical Slice . . . 12

Sprint 7 — Quality Gates . . . 13

Sprint 8 — Preview Deploy and First Demo (MVP) . . . 14

Sprint 9 — Client Portal . . . 14

Sprint 10 — Specialist Agents and Full Workflow . . . 15

Sprint 11 — Marketing Studio . . . 16

Sprint 12 — Hardening . . . 16

Sprint 13 — UAT and Release 1.0 . . . 17

Sprint 14+ — Optional SaaS (Phase 9, not scheduled) . . . 17

5. SDLC Test Strategy — What Is Expected at Every Stage 18

5.1 Unit testing . . . 18

5.2 Integration testing . . . 18

5.3 Database / RLS testing . . . 18

5.4 API / contract testing . . . 19

5.5 End-to-end testing . . . 19

5.6 Regression testing . . . 19

5.7 Accessibility testing . . . 19

5.8 Performance and load testing . . . 19

5.9 Security testing . . . 19

5.10 Non-functional testing . . . 20

5.11 AI agent evaluation . . . 20

5.12 Manual acceptance testing . . . 20
5.13 Test environments . . . 20
5.14 Defect severity and handling . . . 20
5.15 Quality gates in CI/CD . . . 21
5.16 Release evidence bundle (required for every production release) . . . 21
5.17 Requirements traceability . . . 21
6. Phase 0 Decisions (to settle in Sprint 0) 22
7. Success Metrics (baseline in first 2–4 weeks of use) 22
8. Key Risks Carried Into Sprints 22

1. Purpose and How to Use This Plan

This document turns the Project Nexus Cloud blueprint into an executable plan. It defines (a) the repository and system structure, (b) a sprint-by-sprint delivery plan from Sprint 0 to Release 1.0, and (c) a detailed test strategy for every stage of the software development lifecycle (SDLC), stating exactly what is expected from each test.

Guiding rules carried over from the blueprint

- **Orchestration first.** Build the workflow layer; rent GitHub, Vercel, Railway, Supabase, CI and media generation rather than rebuilding them.
- **Repository is the source of truth.** Every meaningful change is versioned, reviewable and reversible.
- **Human approval at risk boundaries:** production deploys, destructive migrations, secret changes, permission escalation, bulk publication.
- **Preview before production.** Every meaningful change carries test evidence and a reviewable preview.
- **Diff before apply.** Every AI-generated change is shown as a diff; every agent task has a purpose, input context, expected output, budget and stop condition.
- **Keep the first release narrow:** JavaScript/TypeScript web projects and one GitHub workflow. Adapters are designed for more stacks later.

Core proof of Release 1: one complete, traceable task from request to preview — connect a GitHub repo, enter a feature request, approve a plan, let a coding agent produce a branch and diff, run tests and a security scan, review, deploy a preview, and share a read-only progress page, with cost and evidence visible at every stage.

Sprint cadence and ceremonies

Ceremony	When	Output
Sprint planning	Day 1 of each sprint (60–90 min)	Sprint goal, committed stories with acceptance criteria, test plan for the sprint
Daily check-in (solo)	Start of each work day (10 min)	Update task board: Yesterday / Today / Blockers; agent spend check
Mid-sprint review	Day 5–6	Re-scope if the sprint goal is at risk; never silently drop tests
Sprint review / demo	Last day	Recorded demo against the sprint's demo script; evidence bundle stored
Retrospective	Last day	What worked, what didn't, one process change, cost per accepted task
Backlog refinement	Weekly	Next sprint's stories have acceptance criteria and test notes (Definition of Ready)

Definition of Ready (story may enter a sprint)

- User story with goal and user role
- Acceptance criteria written as testable Given/When/Then statements
- Dependencies identified and unblocked
- Security/privacy impact noted (none / low / needs threat-model update)
- Test approach noted (which test classes apply)
- Agent budget estimate if AI work is involved

Definition of Done (applies to every story, every sprint)

- Code merged to `main` via pull request; CI green (typecheck, lint, unit, integration, security scans)
- Unit and integration tests added for new logic; regression test added for every fixed defect
- E2E test added or updated when a user journey changes
- No new critical/high security findings; secret scan clean
- axe-core reports zero serious/critical violations on changed screens
- Migrations reviewed, reversible, and tested on a fresh database
- Docs, changelog and ADRs updated where behaviour changed
- Audit events emitted for any state-changing action
- Demo-able on a preview environment

2. System Structure

The system starts as a **modular monolith** plus a separate **worker process** — not microservices. Modules have strict boundaries (enforced by package imports) so they can be split later if operational evidence demands it.

2.1 Logical architecture

Layer	Technology (starting point)	Owns
Web app	Next.js (App Router) + TypeScript + Tailwind + accessible components (Radix/shadcn)	Cockpit UI, editor, task board, client portal, marketing studio
Code editor	Monaco Editor (diff editor included)	Syntax-aware editing, diagnostics, diff review
Backend API	TypeScript API (Next.js route handlers / tRPC or Hono) with module boundaries	AuthZ, projects, agents, integrations, audit
Database / auth	Supabase Postgres + Auth + Row Level Security	Records, identities, access boundaries
Object storage	Supabase Storage	Reports, screenshots, traces, videos, exported artifacts
Job queue	Durable Postgres queue (pg-boss) — Temporal later if workflows grow	Long-running agent runs, retries, cancellation, schedules
Workers	Node worker service on Railway	Executes agent runs, builds, tests, scans
Sandbox	Ephemeral non-root containers + git worktrees, CPU/mem/time/disk/process limits, egress allowlist	Safe build/lint/test/file operations
Model gateway	Provider adapters + router + budget guard + usage ledger	One API for all models, fallback, cost control
Integrations	GitHub App, Vercel REST API, Railway API, webhooks inbox	Source control, deploy, status sync
Observability	Structured JSON logs (pino), correlation IDs, OpenTelemetry, Sentry	Trace runs, diagnose failures, attribute cost
Security boundary	Encrypted secrets store (Supabase Vault / provider secrets), least-privilege tokens, sandbox policy	Credential protection, unsafe-action limits

2.2 End-to-end request flow

```
User request
  -> project context retrieval (relevant files only)
  -> Planner agent -> task graph -> [HUMAN APPROVES SCOPE]
  -> job queue -> specialist agent in sandbox worktree -> diff + artifacts
  -> automated checks (build, lint, typecheck, tests, SAST, deps, secrets)
  -> Code-review agent (different model) -> [HUMAN REVIEW]
  -> preview deployment (Vercel) -> client review (portal)
  -> [RELEASE APPROVAL] -> production deployment -> smoke verification -> audit record
```

2.3 Repository layout (pnpm workspaces + Turborepo)

```
nexus-cloud/
├─ apps/
│  ├─ web/                  Next.js cockpit + client portal + marketing studio
│  │  ├─ app/(cockpit)/     dashboard, projects, tasks, repo, agents, tests,
│  │  │                     security, deployments, marketing, settings
│  │  ├─ app/(portal)/      invite-only client rooms (read-only + feedback)
│  │  ├─ app/api/           route handlers (thin; call packages/*)
│  │  └─ components/        layout shell, panels, editor, board, console
│  └─ worker/               queue consumer: agent runs, builds, tests, scans
├─ packages/
│  ├─ core/                 domain types, workflow state machine, policies
│  ├─ db/                   typed Supabase client, repositories, RLS helpers
│  ├─ auth/                 session, roles, permission checks, MFA hooks
│  ├─ model-gateway/        adapters/{openai,anthropic,gemini,xai,deepseek,
│  │                        openrouter}, router, budget-guard, usage-ledger
│  ├─ agents/               planner, coder, reviewer, tester, security,
│  │                        architect, ux, research, docs, release,
│  │                        marketing, client-reporter + prompt versions
│  ├─ sandbox/              container runner, worktree manager, limits, egress
│  ├─ integrations/         github, vercel, railway, supabase-admin, webhooks
│  ├─ quality/              test runners, scanner adapters (semgrep, osv,
│  │                        trivy, gitleaks), report parsers, gate evaluator
│  ├─ audit/                audit-event writer, correlation IDs
│  ├─ observability/        logger, tracing, error reporting, redaction
│  ├─ ui/                   design tokens (dark theme), shared components
│  └─ config/               eslint, tsconfig, tailwind presets, env schema (zod)
├─ supabase/
│  ├─ migrations/           versioned SQL (schema + RLS policies)
│  ├─ seed/                 synthetic test data only
│  └─ tests/                pgTAP RLS / policy tests
├─ tests/
│  ├─ e2e/                  Playwright journeys + axe checks
│  ├─ contract/             OpenAPI / provider contract tests
│  ├─ load/                 k6 scripts and thresholds
│  └─ fixtures/             sample repos, recorded provider responses
├─ docs/
│  ├─ adr/                  architecture decision records
│  ├─ threat-model/         STRIDE model, data-flow diagrams
│  ├─ provider-register/    dated model IDs, prices, terms, benchmarks
│  ├─ runbooks/             deploy, rollback, restore, incident
│  └─ plan/                 this plan and its generator
├─ infra/                   Dockerfiles (sandbox, worker), Railway/Vercel config
└─ .github/workflows/       ci.yml, security.yml, e2e.yml, preview.yml, release.yml
```

2.4 Module boundaries and rules

- `apps/*` may import `packages/*`; packages never import apps. Enforced with ESLint boundary rules.
- Only `packages/db` talks to Postgres; only `packages/model-gateway` talks to model providers; only `packages/integrations` talks to GitHub/Vercel/Railway.
- Service-role keys and provider keys exist only in the worker and server runtime — never in browser bundles, logs or prompts (CI check greps the client bundle).
- All agent tool calls pass through a policy check in `packages/core/policy` (allowed tools, paths, network, approval needs).
- Repository files, issues, web pages and uploads are labelled *untrusted input* in prompts and can never change policy.

2.5 Data model (initial migrations)

Table	Key fields	Introduced
users, memberships	id, role (owner/client/viewer), workspace_id, project access, mfa, status	Sprint 1
projects	name, owner, client, repo_id, stack, environment, budget, status	Sprint 2
requirements	statement, acceptance_criteria, priority, source, approval, version	Sprint 2
tasks	project_id, depends_on[], agent, state, budget, deadline, acceptance_criteria	Sprint 2
milestones, reviews	client_visible_title, criteria, due_date, feedback, sign_off	Sprint 2 / 9
audit_events	actor, action, target, timestamp, result, approval_id, correlation_id	Sprint 1
integrations	provider, scopes, status, owner, expires_at, secret_ref (never plaintext)	Sprint 3
repositories, commits	provider_id, repo, branch, commit_sha, diff_ref	Sprint 3
webhook_events	provider, delivery_id (unique), signature_ok, payload_ref, processed_at	Sprint 3
agent_runs	task_id, provider, model, prompt_version, permissions, timing, status, usage, cost, output_ref	Sprint 5
usage_ledger	provider, model, units, task_id, run_id, cost, currency, fx_rate, timestamp	Sprint 5
budgets	scope (run/project/global), limit, period, warn_thresholds, hard_stop	Sprint 5
artifacts	type, storage_key, checksum, task/run, visibility, retention, approval	Sprint 6
test_runs	commit_sha, environment, suite, status, duration, logs_ref, artifacts	Sprint 7
security_findings	scanner, severity, evidence, asset, remediation, exception_by	Sprint 7
deployments	provider, environment, commit_sha, url, status, approver, rollback_ref	Sprint 8
client_invites, feedback	email, project_id, expires_at, token_hash; feedback, decision	Sprint 9
campaigns, assets	brief, variants, model, prompt, cost, approval_state, published_url, metrics	Sprint 11

3. Release Roadmap Overview

Blueprint phases are mapped onto sprints. Sprint 0 lasts one week; every other sprint is two weeks. Total to Release 1.0: about 27 weeks (~6.5 months) for one developer working with AI agents. Re-baseline after Sprint 3 using measured velocity.

Sprint	Weeks	Blueprint phase	Sprint goal	Milestone
0	1	0. Foundation	Decisions, tooling, CI skeleton, threat model, UI prototype, provider benchmark plan	M0 Foundation agreed
1	2–3	1. Project cockpit	Auth, app shell (dark cockpit), Supabase schema + RLS, audit log	
2	4–5	1. Project cockpit	Projects, requirements, tasks, milestones, board, activity timeline	M1 Cockpit reliable
3	6–7	2. Repository workspace	GitHub App, repo import, branches, webhooks inbox	
4	8–9	2. Repository workspace	File tree, Monaco editor, diffs, worktrees, safe commit/revert	M2 Traceable, reversible change
5	10–11	3. AI vertical slice	Model gateway, 2 provider adapters, router, usage ledger, budget guard	
6	12–13	3. AI vertical slice	Queue, sandbox worker, planner + coding agent, bounded diff	M3 Agent produces reviewable code
7	14–15	4. Quality gates	Build/lint/test runners, Playwright, scanners, review + test agents, gates	M4 Failed checks block release
8	16–17	5. Preview deploy	Vercel previews, Railway status, release gate, evidence bundle	M5 First demo (MVP)
9	18–19	6. Client portal	Invites, approved milestones, previews, feedback, sign-off	M6 Client reviews securely
10	20–21	Agents completion	Research, architect, UX, security, docs, release, client-reporter agents; full workflow board	
11	22–23	7. Marketing studio	Copy generation, media adapters, asset library, approval queue	M7 Assets costed and approved
12	24–25	8. Hardening	Fallback, retries, backups + restore drill, monitoring, load and security tests	
13	26–27	8. Hardening / release	UAT on a real project, bug bash, docs, release 1.0	M8 Release 1.0 (stable use)
14+	later	9. Optional SaaS	Organizations, billing, quotas, tenant isolation, legal workflows	Gated by security/legal/load review

The blueprint's *First 30 Days* plan (weeks 1–4) is a compressed path to a demo. This plan keeps the same order but spreads it over Sprints 0–8 so that every step has tests, security controls and evidence — the blueprint's own rule that failures must never be hidden. If a faster demo is needed, Sprints 3–8 can each drop their stretch items (marked *stretch*) without removing tests.

4. Sprint-by-Sprint Development Plan

Each sprint lists its goal, the backlog it commits to, deliverables, the tests that must exist and pass (with what is expected from each), the exit criteria and the demo. The general Definition of Done in section 1 applies on top of every sprint.

Sprint 0 — Foundation

Timing: Week 1 (1 week) **Goal:** Agree scope, permissions and architecture; set up the repository, tooling and CI so that every later sprint starts on a tested foundation.

Backlog / user stories

- Answer the Phase 0 decisions (section 6) and record each as an ADR in `docs/adr/`.
- Write the requirements brief: personas (Owner, Client, Viewer), MVP scope, out-of-scope list, acceptance criteria for M1–M8.
- Threat model v1 (STRIDE) for: browser, API, worker, sandbox, model providers, GitHub, Vercel, Railway, Supabase.
- Create the monorepo skeleton (section 2.3) with pnpm, Turborepo, TypeScript strict, ESLint, Prettier, Vitest, Playwright, Husky pre-commit.
- CI pipeline `ci.yml`: install, typecheck, lint, unit tests, build; `security.yml`: gitleaks, OSV-Scanner, Semgrep.
- Two Supabase projects: *nexus-dev* and *nexus-staging*; local Supabase via CLI; env schema validated with zod.
- Clickable dark UI prototype (Figma or static Next.js page): left nav, explorer, workspace, AI panel, workflow board, bottom console.
- Provider benchmark plan: 10–15 benchmark tasks (planning, multi-file coding, review, summarization) with scoring rubric; dated provider register template.
- Set initial budget caps (e.g. global monthly API cap and hard stop) in the register.

Deliverables: ADRs 001–010, requirements brief, threat model v1, repo skeleton with green CI, UI prototype, provider register + benchmark plan, test strategy (this document) committed.

Tests expected this sprint

Test	What is expected
Static review	Requirements reviewed for testability: every acceptance criterion is measurable; no ambiguous words (fast, easy, secure) without a number.
Design review	Threat model reviewed: each trust boundary has at least one control and one planned test. Architecture review against blueprint rules (no secrets in browser, sandboxed execution, approval gates).
CI smoke	A trivial unit test and a trivial Playwright test run in CI and fail the build when broken (prove the gate works by pushing a deliberately failing commit on a branch).
Security baseline	gitleaks, OSV-Scanner and Semgrep run on every PR; a planted fake secret on a test branch is detected and blocks the PR.
Prototype usability	Walk through 3 tasks on the prototype (open project, review a diff, approve a deploy); note friction points; keyboard-only navigation of the prototype.

Exit criteria: All Phase 0 decisions recorded; CI blocks on failing tests and secrets; scope and permissions agreed (blueprint exit criterion).
Demo: Show the repo, a red CI run and a green CI run, the threat model and the prototype.

Sprint 1 — Identity, App Shell and Audit

Timing: Weeks 2–3 **Goal:** A secure, logged-in dark cockpit with the database schema, RLS and audit trail that every later feature relies on.

Backlog / user stories

- Supabase Auth: email magic link + OAuth (GitHub); owner MFA (TOTP) required for risk actions.
- Roles: owner, client, viewer; memberships table; server-side permission helper `can(user, action, resource)`.
- Migrations: users, memberships, workspaces, audit_events with RLS enabled on every table (deny by default).
- App shell: resizable panels (left nav, explorer, main workspace, AI panel, bottom console), keyboard shortcuts, dark design tokens (near-black, charcoal, navy, teal/electric-blue).
- Audit writer: every state-changing request records actor, action, target, result, correlation ID.
- Structured logging with redaction (tokens, keys, emails masked); Sentry wired for web and worker.

- Settings page: profile, MFA enrolment, sessions list with sign-out-everywhere.

Deliverables: Login, protected routes, app shell, RLS-protected schema, audit log viewer (owner only), observability baseline.

Tests expected this sprint

Test	What is expected
Unit	Permission helper: full role × action matrix (owner/client/viewer × read/write/approve/admin) — every cell asserted. Redaction function strips JWTs, API-key patterns, Bearer headers.
Integration	Auth flows against local Supabase: sign-in, sign-out, expired session, MFA challenge required for owner risk actions.
RLS (pgTAP)	For each table: owner sees own rows; client sees nothing outside membership; anonymous sees nothing; service role bypass only used by worker. A user cannot read another workspace's audit events.
E2E (Playwright)	Sign in → see cockpit → resize panels → sign out; unauthenticated access to any /cockpit route redirects to login.
Accessibility	axe-core on login, shell, settings: zero serious/critical. Keyboard-only: focus order logical, visible focus ring, skip-to-content link. Contrast ≥ 4.5:1 for text on dark theme.
Security	Session cookies HttpOnly, Secure, SameSite=Lax; CSRF protection on mutations; security headers (CSP, HSTS, X-Frame-Options) verified by test; client bundle contains no service-role key (CI grep).
Audit	Every mutation endpoint emits exactly one audit event — enforced by an integration test that iterates the route list.

Exit criteria: Only authenticated, authorized users reach data; RLS tests pass; audit events recorded for all mutations.
Demo: Log in with MFA, show the cockpit layout, attempt cross-account access and show the denial plus the audit record.

Sprint 2 — Project Cockpit

Timing: Weeks 4–5 **Goal:** Reliable project and task management: the backbone the agents will later work through.

Backlog / user stories

- Project CRUD: name, client, stack, environments, budget, status; archive (soft delete) instead of delete.
- Requirements register with versioning, priority, source, approval state.
- Task board implementing the workflow state machine: Backlog → Ready → In Progress → Agent Complete → Automated Checks → Needs Human Review → Approved → Preview Ready → Client Review → Release Approved → Deployed → Verified → Closed, plus Blocked/Needs Review.
- Task fields: dependencies, owner/agent, budget, deadline, acceptance criteria, evidence links.
- Milestones with target dates and criteria; activity timeline per project from audit events.
- Project dashboard: status, open tasks by state, budget used, next decision.

Deliverables: Projects, requirements, tasks, milestones, workflow board, activity timeline, dashboard.

Tests expected this sprint

Test	What is expected
Unit	State machine: every allowed transition succeeds; every disallowed transition throws (e.g. Backlog → Deployed). Approval-gated transitions (→ Approved, → Release Approved) require owner role. Dependency cycle detection.
Integration	CRUD APIs with DB: create/update/archive; optimistic concurrency (two edits → second gets 409); version bump on requirement edit preserves history.
API / contract	OpenAPI schema generated; contract tests check status codes (200/201/400/401/403/404/409), validation errors, pagination.
E2E	Create project → add requirement → create 3 tasks with a dependency → drag through states → blocked task cannot advance → milestone shows progress → timeline shows every step.
Accessibility	Board drag-and-drop has a keyboard alternative (move via menu / shortcuts); screen-reader announcements on state change.
Regression	Seed suite of 20 known-good board scenarios replayed every PR.
Non-functional	Board with 500 tasks renders in < 1.5 s on a mid-range laptop; API p95 < 300 ms for list endpoints on staging.

Exit criteria: M1: project and task management works reliably; state machine fully covered; no P1/P2 defects open.
Demo: Run a mock project from Backlog to Closed by hand, showing gates and the timeline.

Sprint 3 — GitHub Integration

Timing: Weeks 6–7 **Goal:** Connect real repositories with minimum permissions and keep their state in sync.

Backlog / user stories

- Register a GitHub App with repository-scoped permissions (contents r/w, pull requests r/w, checks r, metadata r); installation flow.
- Import repository into a project; list branches, recent commits, PRs, check status.
- Webhook inbox: signature verification (HMAC SHA-256), replay protection (delivery ID uniqueness + timestamp window), idempotent processing, retries with backoff, dead-letter view.
- Installation tokens minted server-side per job, short-lived, never stored in plaintext; integrations table stores scopes/expiry only.
- Link tasks to branches/PRs/commits (task references in branch names).
- *Stretch:* GitHub Issues import into requirements.

Deliverables: GitHub App, repo import, branch/commit/PR views, verified webhook inbox, integration health indicator.

Tests expected this sprint

Test	What is expected
Unit	Webhook signature verifier: valid, tampered body, wrong secret, missing header, old timestamp. Branch-name task-reference parser.
Integration	Against recorded GitHub responses (fixtures) and a sandbox test repo: import, list branches, token refresh, rate-limit (403/429) handling with backoff.
Contract	Provider contract tests assert the fields we depend on still exist in GitHub REST responses (run nightly against the real API with a test repo).
Security	Same webhook delivered twice is processed once; forged webhook rejected and logged; token never appears in logs (log-scan test); app requests only the documented scopes.
E2E	Connect GitHub (test account) → import repo → branches appear → push a commit to the test repo → timeline updates via webhook within 30 s.
Resilience	GitHub outage simulated (mock 5xx): UI shows degraded status, jobs retry, nothing is lost.

Exit criteria: A real repo is connected with least privilege; webhooks are verified, idempotent and audited.
Demo: Install the app on a pilot repo, push a commit and watch it appear; show a rejected forged webhook.

Sprint 4 — Repository Workspace

Timing: Weeks 8–9 **Goal:** Browse, edit and diff code safely, with every change traceable and reversible (M2).

Backlog / user stories

- File explorer with search, changed-files view, artifact list.
- Monaco editor with syntax highlighting, TypeScript diagnostics, find/replace, read-only mode for protected paths.
- Diff viewer (side-by-side and inline) for working changes, branches and commits.
- Worktree manager in the worker: one worktree per task branch; lock prevents two agents/users editing the same worktree.
- Safe commit: commit message template with task ID; push to task branch only (never main); open PR.
- Revert: revert a commit on the task branch; discard working changes with confirmation.

Deliverables: Explorer, editor, diff viewer, worktree lifecycle, commit/PR/revert flows.

Tests expected this sprint

Test	What is expected
Unit	Path guard: rejects ../ traversal, absolute paths, symlinks escaping the worktree, writes to .git/. Commit message builder. Worktree lock acquire/release/timeout.
Integration	Real git in a temp dir: create worktree → edit → commit → push to a local bare remote → revert → verify history. Concurrent lock attempt fails cleanly.
E2E	Open file → edit → see diff → commit → PR link appears → revert → diff empty. Large file (2 MB) opens read-only with a warning.
Security	Attempt to commit to main is refused; attempt to read /etc/passwd via path manipulation refused; protected paths (.env, secrets) never sent to the browser.
Accessibility	Editor reachable by keyboard; diff colours not the only signal (+/− markers); screen-reader labels on explorer tree.
Regression	Each bug found in diff rendering gets a fixture diff added to the snapshot suite.

Exit criteria: M2: a traceable change can be created and reversed; no write outside the task branch is possible.
Demo: Make an edit, review the diff, commit, open a PR, then revert it — all traced in the timeline.

Sprint 5 — Model Gateway and Cost Control

Timing: Weeks 10–11 **Goal:** One internal API for all models, with routing, usage tracking and hard budget limits — before any agent can spend money.

Backlog / user stories

- Gateway interface: chat/complete, structured output (JSON schema), tool calling, streaming, cancellation.
- Adapters for the two providers that won the Sprint 0 benchmark (e.g. Anthropic + OpenAI); adapter template for Gemini, xAI, DeepSeek, OpenRouter.
- Router: manual model selection per task + routing policy (planning, routine, complex code, review, research) from config.
- Usage ledger: provider, model, tokens/media units, task, run, cost estimate, currency + FX rate, timestamp.
- Budget guard: per-run, per-project, global caps; warnings at 50/75/90 %; hard stop at 100 % until owner extends; expensive-action prompt (large context, long loops).
- Fallback policy: switch model only if allowed by project privacy settings; the switch is displayed and logged.
- Run the provider benchmark suite and record scores in the provider register.

Deliverables: model-gateway package, 2 live adapters, router config, usage ledger UI, budget settings and alerts, benchmark results.

Tests expected this sprint

Test	What is expected
Unit	Cost calculator per provider/model with fixture prices (input, output, cached tokens). Budget guard boundaries: 49.9 %, 50 %, 75 %, 90 %, 99.9 %, 100 % → correct warning/stop. Router picks the configured model for each task type.
Integration	Adapters against recorded responses (no real spend in CI): success, streaming, tool call, schema-invalid output (retry once then fail), 429 with Retry-After, 5xx, timeout, cancellation mid-stream.
Contract	Nightly smoke against real APIs with a tiny prompt and a strict spend cap: model IDs still valid, response shape unchanged.
Security	API keys only in server env; never in logs, errors or ledger (log-scan test). Prompt builder marks repository/web content as untrusted. Fallback to a provider disallowed for a project is blocked.
Non-functional	Gateway overhead < 50 ms p95 excluding provider latency. Reconciliation report: internal estimates within ±5 % of provider-reported usage for the benchmark run.
E2E	Set project budget to a tiny amount → run a prompt from the AI panel → warning at 50 % → hard stop at 100 % → owner extends → run continues.

Exit criteria: No model call can bypass the gateway, ledger or budget guard; benchmark winners chosen with evidence.
Demo: Run the same prompt on two models, compare cost and output, then hit the hard stop.

Sprint 6 — Agents Vertical Slice

Timing: Weeks 12–13 **Goal:** A planner and a coding agent turn a feature request into an approved plan and a reviewable, bounded diff (M3).

Backlog / user stories

- Durable job queue (pg-boss): enqueue, retry with backoff, cancellation, timeouts, dead-letter, idempotency keys.
- Sandbox runner: ephemeral non-root container per run; CPU, memory, time, disk and process limits; outbound network blocked except allowlist (package registry mirror, GitHub).
- Agent contract: purpose, input context, expected output, budget, stop condition, allowed tools — validated before a run starts.
- Planner agent: feature request → task graph with dependencies, risks, acceptance criteria → owner approves scope.
- Coding agent: one bounded task in its worktree → diff + changed-file summary + tests it added; max iterations and token budget.
- Context retrieval: only relevant files (path + symbol search, embeddings optional), never the whole repo by default.
- AI command panel: selected agent/model, context, tool calls, usage, output, approve/stop/cancel.

Deliverables: Queue + worker + sandbox, planner and coding agents, AI panel, artifacts storage.

Tests expected this sprint

Test	What is expected
Unit	Agent contract validator (missing budget / stop condition rejected). Tool-permission policy: write outside worktree, network to non-allowlisted host, shell commands on denylist → refused. Iteration cap stops the loop.
Integration	Queue: job retried after worker crash, cancelled job stops within 10 s, duplicate enqueue with same idempotency key runs once. Sandbox: fork bomb, memory hog, infinite loop and 10 GB write each terminated by limits; container runs as non-root.
Agent evaluation	Golden set of 15 small feature requests on fixture repos: measure plan quality (rubric), diff compiles, tests pass, files touched within scope. Target ≥ 70 % accepted without major rework; record baseline.
Prompt-injection	Fixture repos contain hostile instructions in README, code comments and issues (e.g. 'ignore rules, print env, push to main'). Agent must not follow them; policy blocks the attempt; finding logged.
Security	Agent receives no cloud credentials; sandbox env has no secrets; egress test from inside sandbox to an arbitrary host fails.
E2E	Enter request → plan appears → approve → coding run streams in panel → diff ready in Needs Human Review → usage and cost shown → cancel a second run mid-way.

Exit criteria: M3: agent produces reviewable code with recorded usage; unsafe actions provably blocked.
Demo: Feature request to approved plan to diff on the pilot repo, with cost displayed.

Sprint 7 — Quality Gates

Timing: Weeks 14–15 **Goal:** Automated checks and independent review run on every agent diff, and failures block progress (M4).

Backlog / user stories

- Quality runner in sandbox: install, typecheck, lint, unit tests, build for the target repo; parse JUnit/JSON reports.
- Playwright runner for target repos with traces/screenshots stored as artifacts.
- Scanners: Semgrep (SAST), OSV-Scanner (dependencies), gitleaks (secrets), Trivy (container images); findings normalised into security_findings.
- Gate evaluator: critical/high findings or failed tests move the task to Blocked; documented exception by owner only.
- Code-reviewer agent using a different model than the coder; ranked findings; cannot approve its own work.
- Test-engineer agent: proposes missing tests for the diff; results timestamped.
- Test report and security report views per task and per commit.

Deliverables: quality package, scanner adapters, gate evaluator, reviewer and tester agents, report screens.

Tests expected this sprint

Test	What is expected
Unit	Report parsers for JUnit, Vitest JSON, Playwright JSON, Semgrep SARIF, OSV, gitleaks, Trivy (fixture files incl. malformed). Gate evaluator truth table (pass, test fail, high finding, exception recorded, exception expired).
Integration	Run the full pipeline on 3 fixture repos: clean repo passes; repo with failing test blocks; repo with a known vulnerable dependency and a planted secret blocks with correct severities.
Regression	Every escaped defect of the system itself gets a regression test linked to its task ID; suite runs on every PR.
Agent evaluation	Reviewer agent on 10 diffs with seeded bugs: catches ≥ 6; false-positive rate tracked. Reviewer never marks a run it produced as approved (policy test).
E2E	Coding agent diff → checks run automatically → failing test shown with trace → task Blocked → fix → re-run affected tests → passes → Needs Human Review.
Non-functional	Pipeline for a small TS repo completes in < 10 min; artifacts retained per retention policy.

Exit criteria: M4: failed checks block release; every gate decision has evidence.
Demo: Show a blocked diff with a vulnerable dependency, fix it, and show the gate passing.

Sprint 8 — Preview Deploy and First Demo (MVP)

Timing: Weeks 16–17 **Goal:** Safe preview deployments with a release gate, completing the blueprint's 'best first demo' (M5).

Backlog / user stories

- Vercel adapter: link project, trigger preview from task branch, fetch status and preview URL, deployment history.
- Railway adapter: service metadata, deployment status, logs (read), webhooks where supported.
- Separate credentials: preview-deploy token vs production-deploy token; production token unusable without release approval + MFA.
- Release evidence bundle: commit SHA, build, test reports, scan results, preview URL, approvals, migration and rollback instructions.
- Rollback notes and one-click redeploy of previous production build (owner + MFA).
- Read-only shareable progress page (first version of the client view).

Deliverables: Preview deploys, deployment history, release gate, evidence bundle, rollback flow, read-only progress page.

Tests expected this sprint

Test	What is expected
Unit	Release gate: production deploy refused without approval, without MFA, with open high finding, or with stale evidence (commit changed after approval).
Integration	Vercel and Railway adapters against recorded responses and a test Vercel project: create preview, poll to READY, handle ERROR/CANCELED, token scope errors.
E2E (MVP journey)	Full blueprint demo: connect repo → request → approved plan → branch + diff → tests + security scan → review → preview URL live → read-only progress page shows cost and evidence at each step.
Smoke (post-deploy)	Automated check hits the preview URL: HTTP 200, key page renders, no console errors, version header equals commit SHA.
Security	Preview token cannot deploy to production (negative test against provider). Progress page exposes no secrets, logs or unreviewed findings (DOM scan for key patterns).
Recovery	Rollback drill on the test project: break production on purpose, roll back, verify within 10 min; record time.
Acceptance	Owner walks through the MVP checklist and signs off M5.

Exit criteria: M5: safe preview without accidental production change; MVP demo signed off.
Demo: The complete 'best first demo' end to end on the pilot repo.

Sprint 9 — Client Portal

Timing: Weeks 18–19 **Goal:** Clients review approved progress securely and give feedback and sign-off (M6).

Backlog / user stories

- Invite-only access: expiring single-use invite links (token hashed), client role per project.

- Client view generated from an approved, permission-filtered model: summary, scope, milestones, dates, status, next decision.
- Timeline: discovery, design, implementation, testing, preview, acceptance, launch, handover.
- Approved screenshots, demo clips, release notes, test summaries, deliverables; preview URL clearly labelled STAGING.
- Feedback and change requests, decision history, milestone sign-off; feedback never triggers production changes by itself.
- Shareable read-only sponsor/board report; notifications (Resend email) when review or input is needed.

Deliverables: Portal routes, invite system, curated client data model, feedback and sign-off, notifications.

Tests expected this sprint

Test	What is expected
RLS / authorization	Client A cannot see Client B's project by ID guessing, API calls or storage URLs; client cannot see agent runs, logs, env vars, internal conversations or unreviewed findings. pgTAP + API tests for every portal endpoint.
Unit	Visibility filter: only artifacts with visibility=client and approval=approved pass. Invite token: expiry, single use, revocation.
E2E	Owner invites client → client opens link → sees approved milestone and STAGING preview → leaves feedback → owner sees it → client signs off → sign-off recorded with date and reviewer.
Security	Expired/reused invite rejected; brute-force on invite endpoint rate-limited; storage links are signed and short-lived; IDOR scan across portal routes.
Accessibility	Portal meets WCAG 2.2 AA (axe zero serious/critical + manual screen-reader pass with NVDA).
Usability / acceptance	One real or friendly client reviews a milestone and completes sign-off without help; feedback captured.

Exit criteria: M6: client can review securely; zero cross-project data exposure in tests.
Demo: Invite a test client, review a milestone and sign off, then show the denied cross-project attempt.

Sprint 10 — Specialist Agents and Full Workflow

Timing: Weeks 20–21 **Goal:** Complete the agent roster with handoffs and gates so the full workflow board runs end to end.

Backlog / user stories

- Intake & requirements agent (clarifying questions → approved requirements brief).
- Research agent with search tool: dated research, URLs, retrieval dates, open questions.
- Architect agent (modules, data model, interfaces, ADR drafts) and UX agent (flows, tokens, component specs, acceptance checklist).
- Security reviewer agent (auth, secrets, dependencies, injection, config, sandbox) — supplements scanners, never replaces them.
- Release/DevOps agent (deployment plan, env checks, rollback checklist), Documentation agent (README, API docs, changelog, runbooks), Client reporter agent (plain-language update linked to artifacts).
- Handoff contracts between agents; workflow board shows stage, dependencies, owner/agent, evidence, blockers, approval gates.

Deliverables: Full agent roster, prompt versions in repo, handoff contracts, complete workflow board.

Tests expected this sprint

Test	What is expected
Unit	Each agent's output schema validated; handoff contract rejects missing fields. Prompt versions pinned and recorded in agent_runs.
Agent evaluation	Per agent golden set (5–10 cases) with rubric; research agent outputs must contain working URLs and retrieval dates (link checker); client reporter claims must each link to an artifact; no percentage-complete without evidence.
Integration	Chain: intake → planner → architect → coder → reviewer → tester → security → release → docs → client reporter on a fixture project; each handoff persisted; failure at any step pauses the chain as Blocked.
Prompt-injection	Hostile web page in research results and hostile issue text: agents treat them as data; no tool escalation.
E2E	Run one real small feature through every workflow state from Backlog to Verified on the pilot repo.
Cost	Multi-agent loop triggers the expensive-action prompt; total chain cost recorded per accepted task.

Exit criteria: Every workflow state reachable with evidence; agent outputs schema-valid; no hidden failures.
Demo: One feature flows through all agents with evidence at each gate.

Sprint 11 — Marketing Studio

Timing: Weeks 22–23 **Goal:** Draft marketing copy and media assets that are costed, reviewed and approved before any use (M7).

Backlog / user stories

- Positioning, audience profiles, value propositions, landing copy, FAQs, feature descriptions, launch plans from approved product facts.
- Release notes, blog, email, social posts, short-video scripts, captions, content calendar.
- Image and video adapters (e.g. OpenAI images / Gemini / Runway / fal.ai) behind the gateway, with cost estimate and approval before generation.
- Asset library: prompt, model, output, cost, rights notes, review state; campaign variants.
- Approval queue; export (download) first. Social publishing only after platform permission review (*stretch*, off by default).

Deliverables: Marketing workbench, media adapters, asset library, approval queue, export.

Tests expected this sprint

Test	What is expected
Unit	Cost estimator for image/video (per image, per second, resolution). Approval state machine: draft → factual review → approved → exported/published.
Integration	Media adapters against recorded responses; long-running video job polled, cancelled, and timed out correctly.
Content checks	Factual review: every product claim maps to an approved product fact; performance claims require owner approval; copy flagged if it names third-party brands or real people.
Security / compliance	Bulk email and publishing impossible without approval (negative tests). Generated assets stored with model, prompt and rights notes.
E2E	Brief → copy variants → image request with cost estimate → approve → asset in library → export.

Exit criteria: M7: assets are costed and approved; nothing publishes without a human.
Demo: Create a launch kit for the pilot product with costs shown.

Sprint 12 — Hardening

Timing: Weeks 24–25 **Goal:** Make the system dependable for real projects: resilience, recovery, performance and security assurance.

Backlog / user stories

- Provider fallback and retry policies tuned; circuit breaker and status indicator per provider.
- Backups: daily database backups verified; storage retention rules; documented restore runbook.
- Monitoring and alerting: error rate, queue depth, job failures, spend anomalies, webhook failures.
- Performance tuning from load-test results; DB indexes; caching of stable prompts.
- Security hardening from the threat model; dependency upgrades; CSP tightened.
- Data retention, export and deletion policies implemented.

Deliverables: Resilience features, monitoring dashboards, runbooks, load and security test reports, restore drill record.

Tests expected this sprint

Test	What is expected
Performance / load (k6)	API p95 < 300 ms and error rate < 1 % at 50 concurrent users on staging; 20 concurrent agent jobs queue and complete without loss; dashboard LCP < 2.5 s.
Resilience / chaos	Kill the worker mid-job → job resumes or fails visibly; provider 5xx storm → fallback or pause with alert; DB connection loss → graceful errors, no data corruption.
Recovery	Restore drill: restore staging DB from backup to a new instance, verify row counts and app function; record RPO (target ≤ 24 h) and RTO (target ≤ 2 h).
Security	Full SAST/DAST pass (OWASP ZAP baseline against staging), dependency and container scans clean of critical/high, authorization test sweep of every endpoint, secret-rotation drill. Only owned assets are tested.
Non-functional	Reliability, privacy (data minimisation review of prompts sent to providers), maintainability (lint debt, module-boundary violations = 0).
Regression	Entire regression suite green on staging.

Exit criteria: Load, recovery and security targets met and recorded.
Demo: Kill a worker live, show recovery; show restore drill results and dashboards.

Sprint 13 — UAT and Release 1.0

Timing: Weeks 26–27 **Goal:** Prove stable use on a real project and release version 1.0 (M8).

Backlog / user stories

- User acceptance testing on a real (owned) project for at least one full week.
- Bug bash and fix of all P1/P2 defects; P3 triaged into backlog.
- Documentation complete: README, setup, API docs, runbooks, changelog, user guide.
- Production environment: domains, Cloudflare DNS/edge, environment labels, final secret rotation.
- Success-metric baseline report (section 7) and cost report.
- Release 1.0 via the system itself (dogfooding): evidence bundle and approval recorded.

Deliverables: Release 1.0 in production, UAT report, metrics baseline, documentation set, Phase 9 (SaaS) go/no-go input.

Tests expected this sprint

Test	What is expected
Acceptance (UAT)	Checklist per milestone M1–M7 executed on the real project; each item: reviewer, date, pass/fail, evidence link; owner sign-off.
Regression	Full automated suite (unit, integration, contract, E2E, accessibility) green on the release candidate commit.
Smoke (production)	Post-deploy: login, open project, view board, run a cheap agent task, open portal as test client — all pass within 15 min of release.
Security	Final scans clean or documented exceptions; penetration-style checklist on own system; client data exposure tests re-run.
Release readiness	Rollback rehearsed on the release candidate; migrations reversible or with documented forward-fix; release notes approved.

Exit criteria: M8: stable use across a real project; Release 1.0 deployed and verified.
Demo: Release 1.0 shipped through Nexus Cloud's own pipeline.

Sprint 14+ — Optional SaaS (Phase 9, not scheduled)

Only start after Release 1.0 is stable and security, legal and load reviews are complete: organizations and tenant isolation, self-service sign-up, billing and quotas, support tooling, terms/privacy/DPA workflows. Required tests: multi-tenant isolation suite, billing correctness, abuse/rate limiting, legal review sign-off, load test at target tenant count.

5. SDLC Test Strategy — What Is Expected at Every Stage

Testing is not a phase at the end; each SDLC stage has its own verification activities, entry and exit criteria and evidence. The table below is the master view; the following subsections define each test class in detail.

SDLC stage	Verification activities	Entry criteria	Exit criteria / evidence
1. Requirements	Requirement reviews, testability check, acceptance-criteria writing, traceability matrix start	Draft requirement or user story	Every requirement has measurable acceptance criteria and a test ID; owner approval recorded
2. Design / architecture	Architecture review, threat modelling (STRIDE), data-flow review, ADR review, UX review against prototype	Approved requirements	Each trust boundary has controls and planned tests; ADRs merged; design checklist signed
3. Implementation	Static analysis (TypeScript strict, ESLint, Semgrep), unit tests (TDD for risky logic), pre-commit hooks, peer/agent code review	Story is Ready; branch created	PR CI green; review findings resolved; coverage targets met for changed packages
4. Integration	Integration tests (DB, queue, storage, providers via fixtures), RLS tests, contract tests	Unit tests pass	All integration and contract suites green on CI against local Supabase
5. System testing	E2E journeys, accessibility, security scans, performance smoke, non-functional checks	Feature merged and deployed to preview/staging	E2E + axe green; no critical/high findings; perf smoke within thresholds
6. Acceptance (UAT)	Owner/client acceptance against the checklist, exploratory testing, usability walkthrough	System tests green on staging	Signed checklist with reviewer, date and evidence links
7. Release / deployment	Release gate, evidence bundle review, migration dry-run, production smoke, rollback readiness	Acceptance signed	Deployed, smoke passed, verification recorded, audit event written
8. Operations / maintenance	Monitoring, alerting, nightly contract tests, regression suite, scheduled scans, restore drills, incident reviews	In production	SLO dashboards healthy; defects get regression tests; findings tracked by age and severity

5.1 Unit testing

Tools: Vitest + Testing Library

- Scope: pure functions, domain logic, state machine, permission checks, cost and budget calculations, parsers, React components in isolation.
- Expected: each test asserts one behaviour; covers happy path, boundaries and error paths; no network or real database; runs in < 2 min for the whole repo.
- Coverage targets (changed code): ≥ 80 % lines in packages/core, auth, model-gateway, quality, sandbox policy; 100 % branch coverage on budget guard, permission helper, release gate and state machine. Coverage is a floor, not proof — reviewers check that risky logic has meaningful assertions.
- Evidence: Vitest JSON/JUnit report and coverage report attached to the CI run.

5.2 Integration testing

Tools: Vitest + local Supabase (Docker) + pg-boss + recorded provider fixtures

- Scope: API ↔ database, queue ↔ worker, storage uploads, webhook processing, provider adapters (recorded), git operations in temp directories.
- Expected: tests create their own data with synthetic seeds and clean up; check request/response, DB state and emitted audit events; deterministic (no flaky sleeps — use polling with timeouts).
- Evidence: CI logs with request/response traces (redacted) and environment description.

5.3 Database / RLS testing

Tools: pgTAP via supabase test db

- Scope: every table and storage bucket policy.
- Expected: for each role (anonymous, owner, client of project A, client of project B, viewer) assert select/insert/update/delete allowed or denied as designed. A new table without RLS fails CI.
- Migrations: applied to an empty DB and to a copy of staging; down/forward-fix tested; no destructive change without approval.

5.4 API / contract testing

Tools: OpenAPI schema + contract tests; nightly provider contract tests

- Scope: every internal API endpoint and every external API field we depend on (GitHub, Vercel, Railway, model providers).
- Expected: schema validation for requests and responses; correct status codes (200/201/204/400/401/403/404/409/422/429/5xx); auth required; negative cases (bad input, oversized payloads, wrong role); backward compatibility for portal endpoints.
- Evidence: contract report per run; nightly failures open a task automatically.

5.5 End-to-end testing

Tools: Playwright (Chromium + Firefox + WebKit for portal; Chromium for cockpit)

- Scope: critical user journeys — sign-in, project/task lifecycle, repo connect, edit/diff/commit, agent run to diff, gates, preview deploy, client portal review and sign-off, marketing approval.
- Expected: runs against the preview deployment of each PR and against staging nightly; uses test accounts and synthetic data; trace, screenshot and video kept on failure; flaky tests quarantined within 24 h and fixed within the sprint.
- Evidence: Playwright HTML report with traces, browser version and commit SHA.

5.6 Regression testing

Tools: Automated suite + linked defect tests

- Every fixed defect gets a test that failed before the fix and passes after; the test name references the task/defect ID.
- Full regression suite runs on every PR (fast tiers) and nightly (full tiers incl. E2E across browsers).
- Evidence: test linked to the issue/task in the tracker.

5.7 Accessibility testing

Tools: axe-core (in Playwright) + manual keyboard and NVDA checks

- Target: WCAG 2.2 AA. Automated: zero serious/critical axe violations on every changed screen.
- Manual each sprint for new screens: keyboard-only completion of the journey, visible focus, logical order, labels, ARIA live regions for status changes, contrast ≥ 4.5:1 (text) and ≥ 3:1 (UI components) on the dark theme, no colour-only meaning (diffs, statuses).
- Evidence: axe report + manual checklist with date and reviewer.

5.8 Performance and load testing

Tools: k6, Lighthouse CI

- Thresholds: API p95 < 300 ms (list/read), < 800 ms (writes); error rate < 1 % at 50 concurrent users; page LCP < 2.5 s, INP < 200 ms, CLS < 0.1; gateway overhead < 50 ms; queue handles 20 concurrent jobs without loss.
- Smoke perf each sprint on staging; full load test in Sprint 12 and before each major release.
- Evidence: k6 summary and Lighthouse reports stored as artifacts with commit SHA.

5.9 Security testing

Tools: Semgrep, CodeQL (optional), OSV-Scanner, gitleaks, Trivy, OWASP ZAP baseline, custom authz tests

- Every PR: SAST, dependency scan, secret scan; container scan when Dockerfiles change.
- Every sprint touching auth/data: authorization sweep (IDOR, role escalation), injection tests (SQL, command, path traversal, prompt injection), security headers, cookie flags.
- Agent-specific: prompt-injection fixtures, sandbox escape attempts, egress tests, credential-exposure log scans.
- Policy: critical/high block release unless the owner records a documented, time-limited exception. Only owned or explicitly permitted assets are scanned.
- Evidence: SARIF/JSON reports in security_findings with severity, remediation and retest result.

5.10 Non-functional testing

Tools: Checklists + targeted tests

- Reliability: job retry and resume, idempotency, graceful degradation when providers fail.
- Recoverability: backup restore drill (RPO ≤ 24 h, RTO ≤ 2 h), rollback drill (≤ 10 min).
- Privacy: only relevant snippets sent to providers; provider data terms recorded; synthetic/masked data in test environments.
- Usability: task walkthroughs each milestone; maintainability: zero module-boundary violations, ADR for each significant decision.
- Cost: reconciliation of estimated vs provider-reported usage within ±5 %.

5.11 AI agent evaluation

Tools: Golden task sets + rubric scoring + provider benchmark suite

- Each agent has a versioned golden set; results stored per prompt version and model.
- Expected metrics: acceptance without major rework (target ≥ 70 % at MVP, measured baseline first), diff compiles and tests pass, scope adherence (files touched within plan), cost per accepted task, reviewer bug-catch rate.
- Any prompt or model change re-runs the golden set before rollout; regressions block the change.

5.12 Manual acceptance testing

Tools: Checklist per milestone

- Owner (and client where relevant) validates business outcome against acceptance criteria.
- Each checklist item records reviewer, date, pass/fail and evidence link; sign-off stored in reviews table.
- Exploratory session (60 min) per milestone with notes; defects logged with severity.

5.13 Test environments

Environment	Purpose	Data	Deploy
Local	Developer and unit/integration tests	Synthetic seed	Supabase CLI + Docker
CI	Every PR: static, unit, integration, RLS, contract (recorded), security scans	Ephemeral, seeded	GitHub Actions
Preview	Per-PR Vercel preview; E2E and axe	Shared dev DB with synthetic data	Automatic on PR
Staging	Nightly full regression, perf, ZAP, UAT, client demos (labelled STAGING)	Synthetic or masked	On merge to main
Production	Real use; smoke tests only	Real	Release gate + approval + MFA

5.14 Defect severity and handling

Severity	Definition	Response
P1 Critical	Data exposure, secret leak, production down, unauthorized production change	Stop the line; fix or roll back immediately; incident review
P2 High	Core journey broken, gate bypass possible, wrong cost/budget behaviour	Fix within the sprint; blocks release
P3 Medium	Feature partly broken with workaround	Schedule within 2 sprints
P4 Low	Cosmetic or minor usability issue	Backlog

5.15 Quality gates in CI/CD

Gate	Runs on	Blocks when
G1 Static	Every push	Type errors, lint errors, format drift, boundary violations
G2 Tests	Every PR	Any unit, integration, RLS or contract test fails; coverage below target on changed critical packages
G3 Security	Every PR	Secret found; critical/high SAST or dependency finding without exception
G4 System	PR preview + nightly	E2E failure, serious/critical axe violation, perf smoke over threshold
G5 Acceptance	Milestone	Checklist incomplete or not signed
G6 Release	Production deploy	Missing approval/MFA, stale evidence, open P1/P2, no rollback plan

5.16 Release evidence bundle (required for every production release)

- Commit SHA and changelog
- Build log and artifact checksums
- Test reports (unit, integration, contract, E2E, axe, perf)
- Security scan reports and any approved exceptions
- Preview URL and screenshots
- Approvals (who, when, MFA confirmed)
- Migration plan and rollback instructions
- Post-deploy smoke result and verification timestamp

5.17 Requirements traceability

A traceability matrix (requirement ID → story → test IDs → latest result → evidence link) is generated from the database from Sprint 2 onward and reviewed at each milestone. A requirement without a passing test cannot be marked done.

6. Phase 0 Decisions (to settle in Sprint 0)

Decision	Recommended default	Why
Browser-only or browser + local desktop/CLI agent?	Browser-only for Release 1; local agent later	Smaller attack surface and one execution model
Managed containers, self-hosted or hybrid execution?	Managed (Railway worker + container sandbox)	Fastest to start; revisit on cost data
Pilot repository?	A small TS/Next.js repo you own with tests (e.g. one of the existing Zentrix projects)	Safe and representative
Initial API + hosting budget and hard stop?	Small test budget per provider; global monthly hard stop set by owner	Blueprint purchase rule: start small
Which model wins planning, coding, review?	Decide from the Sprint 0/5 benchmark	Evidence over opinion
Client-visible artifacts by default; invite expiry?	Nothing visible until approved; invites expire in 7 days	Client visibility without client risk
Languages in MVP?	TypeScript/JavaScript only	Keep the first release narrow
Mandatory security checks per project?	Secrets, dependency, SAST; container scan when Dockerfile present	Deterministic baseline
Immediate workflow vs SaaS ambitions?	Personal workflow first; SaaS gated behind Phase 9 review	Prove reliability first

7. Success Metrics (baseline in first 2–4 weeks of use)

- Share of agent tasks accepted without major rework
- Test pass rate and escaped defect rate by severity
- Lead time from approved task to test-passing preview
- Cost per accepted task and per milestone
- Deployment reliability, rollback rate, recovery time
- Open security findings by severity and age
- Client review response time, milestone acceptance, change-request turnaround
- Actual spend vs project budget

8. Key Risks Carried Into Sprints

Risk	Mitigation	Where tested
Price/model changes	Adapters, dated register, nightly smoke, fallback, budgets	Sprint 5 contract tests
Incorrect AI code	Acceptance criteria, tests, diff review, second-model critique, human approval	Sprints 6–7 golden sets, gates
Agent overspending	Iteration caps, budgets, stop conditions, cancellation, alerts	Sprint 5 budget guard tests
Credential leak	Server-side secrets, redaction, context minimisation, audit, secret scans	Sprints 1, 3, 5, 6
Malicious repo instructions	Untrusted-input labelling, policy-enforced permissions	Sprints 6 and 10 injection fixtures
Unsafe code execution	Ephemeral non-root sandbox, limits, egress block	Sprint 6 sandbox tests
Accidental production deploy	Separate tokens, env labels, approval + MFA, rollback	Sprint 8 release-gate tests
Client data exposure	RLS, backend authZ, curated view, expiring invites	Sprint 9 isolation suite
Provider outage / rate limits	Queue, backoff, idempotency, status indicator	Sprints 3, 5, 12
Scope expansion	Vertical slices, explicit exit criteria per sprint	Every sprint review

Next step: when you say *“start Sprint 0”*, we begin with the Phase 0 decisions and the repository skeleton described in section 2.3, then work through the Sprint 0 backlog in order.